

 CONFIDENCIAL

Reporte de Vulnerabilidades

Information Disclosure, componente EOL y configuración — Análisis pasivo de respuesta HTTP

ID del Ticket	VULN-2026-003
Activo evaluado	Aplicación web con formulario de verificación (<code>index.php</code>)
Severidad global	MEDIA 4 hallazgos + 4 observaciones informativas
Metodología	Análisis estrictamente pasivo (observación de respuesta HTTP)
Analista	J. M. F. · jmf01111974@gmail.com
Fecha del reporte	06 de octubre de 2026
Versión	1.0

Contenido

1. Resumen Ejecutivo	pág. 2
2. Resumen de Hallazgos	pág. 2
3. Evidencia	pág. 3
4. Detalle de Hallazgos (con CVSS)	pág. 3
5. Recomendaciones de Remediación	pág. 6
6. Alcance, ética y referencias	pág. 6

Evaluación realizada mediante observación pasiva de una única respuesta HTTP. No se ejecutaron pruebas activas, fuzzing ni intentos de explotación. Varios puntos se reportan como «potenciales» por requerir validación del lado servidor, que queda fuera del alcance pasivo.

1. Resumen Ejecutivo

Audiencia: dirección y responsables de negocio. Redactado sin tecnicismos.

¿Qué encontramos?

Observando la respuesta que la aplicación envía al navegador, se detectó que el servidor **revela la tecnología y la versión exacta** con la que funciona (`PHP 8.0.30`), y que esa versión **pertenece a una rama que ya no recibe actualizaciones de seguridad**. Además, la aplicación presenta una **configuración de intercambio entre orígenes (CORS) permisiva** y un **formulario con un código de solo 3 dígitos** cuyo control contra intentos automatizados no puede confirmarse desde fuera.

¿Por qué importa para el negocio?

Ninguno de los hallazgos expone por sí solo datos de clientes, pero en conjunto **facilitan el trabajo de un atacante**: saber la versión exacta le permite buscar fallas conocidas; usar software sin soporte implica quedar expuesto a vulnerabilidades que ya no se parchean; y un código de acceso tan corto podría ser adivinado por prueba y error si no hay protecciones adecuadas en el servidor.

¿Qué tan grave es?

Severidad global Media. El punto más accionable es **actualizar PHP** a una versión soportada y **dejar de revelar la versión**. El código de 3 dígitos amerita una revisión específica del backend.

¿Qué hay que hacer?

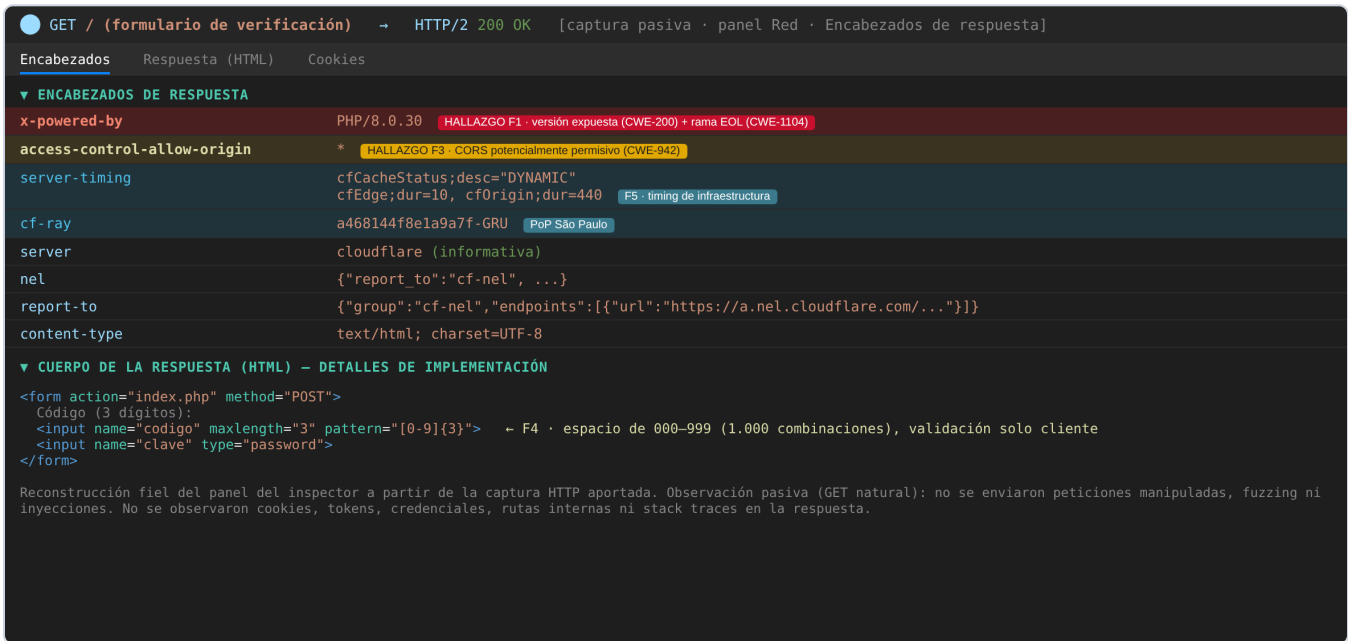
Eliminar la cabecera que revela la versión, actualizar PHP a una rama con soporte, restringir la política CORS a los orígenes necesarios y verificar que el formulario tenga límite de intentos y validación en el servidor.

2. Resumen de Hallazgos

ID	Hallazgo	Evidencia	CWE	CVSS	Severidad
F1	Exposición de tecnología y versión	<code>X-Powered-By: PHP/8.0.30</code>	CWE-200	5.3	MEDIA
F2	Componente fuera de soporte (EOL)	<code>PHP 8.0.30</code> (rama EOL)	CWE-1104	7.3*	ALTA*
F3	Configuración CORS potencialmente permisiva	<code>Access-Control-Allow-Origin: *</code>	CWE-942	5.3*	POTENCIAL
F4	Código de 3 dígitos / controles anti-automatización no verificables	<code>pattern="[0-9]{3}"</code>	CWE-307 / 521	7.5*	POTENCIAL
F5	Divulgación de timing/infraestructura	<code>Server-Timing</code> , <code>Cf-Ray</code> , <code>NEL</code>	CWE-200	0.0	INFO
—	Identificación de CDN (Cloudflare)	<code>Server: cloudflare</code>	—	—	INFO

* CVSS condicional: F2 depende de las CVE no parcheadas aplicables a la versión; F3 y F4 requieren validación del lado servidor (fuera del alcance pasivo). Se indica el escenario de peor caso razonable.

3. Evidencia



Evidencia 1 — Reconstrucción del panel «Red → Encabezados» y del cuerpo HTML a partir de la respuesta HTTP aportada. En rojo/amarillo los hallazgos; en azul la información de infraestructura; abajo, el formulario con el código de 3 dígitos. Observación pasiva: sin peticiones manipuladas.

✓ **No observado en la respuesta** (buena práctica de no sobre-reportar): no aparecen contraseñas, tokens, cookies, API keys, rutas internas, IP privadas, stack traces, consultas SQL ni información personal.

4. Detalle de Hallazgos (con CVSS)

F1 — Exposición de tecnología y versión (X-Powered-By)

Descripción. El servidor incluye **X-Powered-By: PHP/8.0.30**, revelando el runtime y su versión exacta sin necesidad de fingerprinting adicional. Facilita la búsqueda de vulnerabilidades conocidas y la selección de técnicas de ataque específicas.

CWE	CWE-200 — Exposure of Sensitive Information to an Unauthorized Actor
OWASP	A05:2021 — Security Misconfiguration
CVSS v3.1	5.3 (Media) — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Nota: por tratarse de divulgación de baja sensibilidad, la severidad efectiva de triaje suele ser Baja; el valor 5.3 es el puntaje base mecánico (C:L). El verdadero riesgo se materializa combinado con F2.

F2 — Componente fuera de soporte / EOL (PHP 8.0)

Descripción. `PHP 8.0.30` es la última versión de la rama **8.0**, **que alcanzó su fin de vida (EOL)**: ya no recibe parches de seguridad. Operar sobre una rama sin soporte implica exposición permanente a vulnerabilidades futuras que no serán corregidas por el proveedor. Este es el punto de mayor preocupación real del conjunto —no por la visibilidad del dato, sino por la deuda de seguridad que representa.

CWE	CWE-1104 — Use of Unmaintained Third Party Components
OWASP	A06:2021 — Vulnerable and Outdated Components
CVSS v3.1	7.3 (Alta)* — <code>CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L</code>

* Estimación de peor caso razonable para un componente EOL expuesto a red. El puntaje real depende de las CVE sin parchear aplicables en el momento; debe recalcularse según las vulnerabilidades concretas de la versión en producción.

F3 — Configuración CORS potencialmente permisiva

Descripción. La respuesta incluye `Access-Control-Allow-Origin: *`. Esto permite solicitudes cross-origin desde cualquier dominio. **No constituye por sí solo una vulnerabilidad confirmada**: el impacto depende de qué recursos se exponen, si requieren autenticación y si se permiten credenciales (`Access-Control-Allow-Credentials`). Sobre una página de formulario pública, el riesgo es limitado; sobre endpoints autenticados, podría permitir lectura cross-origin de datos.

CWE	CWE-942 — Permissive Cross-domain Policy with Untrusted Domains
OWASP	A05:2021 — Security Misconfiguration
CVSS v3.1	5.3 (Media)* condicional — <code>CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N</code>

* Reportado como **potencial**. Validar: ¿el `*` aplica a endpoints con datos sensibles o autenticados? ¿Se combina con `Allow-Credentials: true` ? (combinación inválida en navegadores, pero indicadora de mala configuración). Confirmar antes de asignar severidad definitiva.

F4 — Código de 3 dígitos y controles anti-automatización no verificables

Descripción. El formulario define `pattern="[0-9]{3}"` para el campo `codigo`, un espacio de solo **1.000 combinaciones (000–999)**. El `pattern` HTML es validación **solo del lado cliente** y se puede omitir trivialmente enviando el `POST` directamente. Desde la observación pasiva **no es posible determinar** si el backend aplica rate limiting, bloqueo por intentos, CAPTCHA, MFA o validación server-side. Si estos controles faltaran, el código sería vulnerable a fuerza bruta.

CWE	CWE-307 — Improper Restriction of Excessive Authentication Attempts · CWE-521 — Weak Password Requirements
OWASP	A07:2021 — Identification and Authentication Failures
CVSS v3.1	7.5 (Alta)* escenario de peor caso — <code>CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N</code>

* Condicional, **no confirmado por métodos pasivos**. El 7.5 asume que el código habilita acceso a información protegida y que no existen controles anti-fuerza bruta. Debe validarse específicamente ese flujo (de forma autorizada y controlada) antes de confirmarlo. Si hay rate limiting/MFA efectivos, la severidad baja drásticamente.

F5 — Divulgación de timing e infraestructura (informativa)

Descripción. Las cabeceras `Server-Timing: cfOrigin;dur=440` (tiempo de procesamiento en el origen), `cfCacheStatus;desc="DYNAMIC"`, `Cf-Ray: ...-GRU` (PoP de Cloudflare asociado a São Paulo) y `NEL/Report-To` revelan detalles operativos de la infraestructura. Útiles para fingerprinting, pero **no constituyen una vulnerabilidad por sí mismas**. `Server: cloudflare` es meramente informativo y puede ser deseable.

CWE	CWE-200 — Information Exposure (bajo/informativo)
CVSS v3.1	0.0 (Informativo) — sin impacto directo

5. Recomendaciones de Remediación

5.1 F1 — Ocultar la versión de PHP

```
# php.ini — no anunciar PHP en las cabeceras
expose_php = Off
# y/o eliminar la cabecera en el servidor web (Nginx):
proxy_hide_header X-Powered-By; # o 'more_clear_headers "X-Powered-By";' (headers-more)
# Apache:
Header unset X-Powered-By
```

5.2 F2 — Actualizar a una rama de PHP con soporte

Migrar PHP 8.0 a una versión actualmente soportada con parches de seguridad activos, previa prueba de compatibilidad. Establecer un proceso de gestión de versiones/EOL para componentes de terceros.

5.3 F3 — Restringir CORS

```
# Devolver solo orígenes de confianza, no comodín, en endpoints sensibles
Access-Control-Allow-Origin: https://app.midominio.com
Vary: Origin
# Nunca combinar '*' con Access-Control-Allow-Credentials: true
```

5.4 F4 — Endurecer el flujo de verificación

- **Validación server-side** obligatoria del formato y rango (no confiar en `pattern` del cliente).
- **Rate limiting** y bloqueo progresivo por IP/sesión tras intentos fallidos.
- Añadir **CAPTCHA** tras N fallos y considerar **MFA** o un código de mayor entropía/expiración corta.
- Registrar y alertar sobre picos de intentos (detección de automatización).

5.5 F5 — Minimizar cabeceras de diagnóstico (opcional)

Si se busca reducir la superficie de información, evaluar si `Server-Timing` con `cf0origin;dur` es necesario para usuarios finales y suprimirlo en respuestas públicas.

5.6 Plan de acción

Acción	Responsable	Prioridad	Plazo	Estado
Actualizar PHP a rama con soporte (F2)	Infraestructura / Dev	Alta	30 días	Pendiente
Ocultar <code>X-Powered-By</code> (F1)	Plataforma	Media	7 días	Pendiente
Revisar/validar flujo del código 3 dígitos (F4)	Desarrollo / Seguridad	Alta	14 días	Pendiente
Revisar política CORS por endpoint (F3)	Desarrollo	Media	14 días	Pendiente
Re-test de verificación	Analista de seguridad	Alta	Tras los fixes	Pendiente

6. Alcance, ética y referencias

Declaración de alcance y ética

Este reporte se basa en la **observación pasiva de una única respuesta HTTP** aportada como evidencia. No se ejecutaron pruebas activas, fuzzing, intentos de autenticación ni explotación. Los hallazgos marcados como «potenciales» (F3, F4) y la severidad de F2 **requieren validación adicional autorizada** del lado servidor para confirmarse. Se aplicó el criterio de **no sobre-reportar**: la información puramente operativa se clasifica como informativa.

Referencias

- CWE-200 — Exposure of Sensitive Information: <https://cwe.mitre.org/data/definitions/200.html>
- CWE-1104 — Use of Unmaintained Third Party Components: <https://cwe.mitre.org/data/definitions/1104.html>
- CWE-942 — Permissive Cross-domain Policy: <https://cwe.mitre.org/data/definitions/942.html>
- CWE-307 — Improper Restriction of Excessive Authentication Attempts: <https://cwe.mitre.org/data/definitions/307.html>

- OWASP Top 10 (2021) — A05 Security Misconfiguration / A06 Vulnerable Components / A07 Auth Failures: <https://owasp.org/Top10/>
- CVSS v3.1 Calculator (FIRST): <https://www.first.org/cvss/calculator/3.1>

Historial de cambios

Versión	Fecha	Autor	Cambio
1.0	2026-10-06	J. M. F.	Creación del reporte a partir del análisis de la respuesta HTTP.

 Documento confidencial — uso académico / profesional autorizado. Evaluación pasiva.